Resultados de pruebas de vulnerabilidades

SSGUI · Sistema de Solicitud de Gestión de Usuarios Interno · ANDINA S.A.S. (empresa ficticia; todos los datos son ficticios)
José Bedoya, Carlos Ruiz, Luis Cerón y Cristian Caro · Institución Universitaria Politécnico Grancolombiano · Taller de Desarrollo Seguro de Software · Grupo G01
Docente: José Eduardo Patiño Santafé · Entregable 2 de 4 · 25 de octubre de 2026

1. Resumen

Este documento presenta los resultados obtenidos con escáneres de vulnerabilidades sobre el sistema SSGUI. Las pruebas se realizaron en dos posiciones: a través del cortafuegos de aplicaciones web (WAF), que representa la defensa completa, y directamente contra la aplicación, sin el borde, con el fin de evaluar el código por sí mismo.

El resultado global es favorable: no se detectó ninguna inyección SQL, ningún escáner activo produjo alertas confirmadas y no se encontraron vulnerabilidades críticas ni altas explotables. Los hallazgos restantes son de configuración y de mantenimiento, y se describen con su corrección propuesta.

Tabla 1. Resumen de herramientas y resultados

Herramienta	Objetivo evaluado	Resultado
OWASP ZAP, escaneo activo	Aplicación a través del WAF, con los roles de RRHH y de técnico	0 alertas FAIL; una alerta alta de confianza baja, descartada como falso positivo
OWASP ZAP, escaneo activo	Aplicación directa, sin WAF, con los mismos roles	0 alertas FAIL en ambos roles
sqlmap, nivel 3	Cuatro objetivos a través del WAF	0 parámetros inyectables; el WAF bloqueó las cargas
sqlmap, nivel 5	Ocho objetivos directos, con la cabecera Host y segundo orden	0 parámetros inyectables
nmap, todos los puertos	Equipo anfitrión y tres redes internas	Solo los puertos 80 y 443 del WAF son accesibles desde el exterior
testssl.sh	Capa TLS del borde	Solo TLS 1.2 y 1.3; ninguna de las vulnerabilidades probadas
Trivy con CISA KEV y EPSS	Cinco imágenes de contenedores	La imagen propia no tiene vulnerabilidades críticas; ninguna de 139 CVE figura en KEV
Nikto	Aplicación a través del WAF	Dos avisos informativos
Docker Bench for Security (CIS)	Contenedores en ejecución	42 comprobaciones; 12 avisos de endurecimiento
Auditoría de configuración de bases de datos	PostgreSQL y MariaDB	La inmutabilidad y los permisos mínimos se imponen en el motor

2. Alcance, reglas y precauciones

Todas las pruebas se ejecutaron sobre la arquitectura de referencia del proyecto, que es local: el WAF BunkerWeb, la aplicación Django, un trabajador de integración, PostgreSQL 17 como base de datos de la aplicación, GLPI 11 y MariaDB 11.4, desplegados con Docker Compose en Docker Desktop. Antes de cada escáner se respaldó la base de datos y se detuvo el trabajador, y al terminar se restauró el estado. No se realizó ninguna prueba activa contra Supabase Auth, único servicio externo, ni contra otros terceros.

Se aplicaron las siguientes precauciones en cada corrida:

1. **Neutralización previa.** Antes de cada escáner se creó una copia de la base de datos, se detuvo el trabajador de integración (para que las solicitudes enviadas por el escáner no generaran tickets en GLPI), se levantaron los bloqueos del WAF y se incorporó un identificador de correlación de laboratorio en la cabecera X-Request-ID.
2. **Restauración posterior.** Al finalizar se restauró la base de datos y se verificó que el número de filas coincidiera con el inicial (414 registros de auditoría, 21 solicitudes, 88 tickets y 75 colaboradores).
3. **Control positivo.** Antes de aceptar el resultado de ZAP y de sqlmap, se comprobó que ambos detectaran las vulnerabilidades sembradas en una aplicación de laboratorio deliberadamente vulnerable (inyección SQL, secuencias de comandos entre sitios y cabeceras ausentes). Un escáner que no detecta lo sembrado no aporta evidencia.
4. **Exención documentada.** Para medir la aplicación sin que el WAF interrumpiera la prueba, se relajaron temporalmente los límites de frecuencia y el bloqueo por mal comportamiento. El conjunto de reglas OWASP

CRS permaneció en modo de bloqueo: un ataque de control produjo el código 403 antes y después de cada corrida. Las mediciones con y sin exención se informan por separado.

3. Escaneo activo con OWASP ZAP

Tabla 2. Resultados de ZAP en tres posiciones

Posición	Alertas FAIL	Alertas WARN	Reglas superadas
A través del WAF, con exención (RRHH / técnico)	0 / 0	3 / 4	140 / 139
A través del WAF, sin exención (RRHH / técnico)	0 / 0	1 / 2	142 / 141
Directo a la aplicación (RRHH / técnico)	0 / 0	5 / 6	138 / 137

En la segunda posición, el WAF bloqueó la dirección IP del escáner durante el primer minuto. Por ello, esa corrida demuestra la eficacia del bloqueo, pero no permite concluir nada sobre la aplicación; para ello se realizaron las otras dos.

Tabla 3. Análisis de las alertas de severidad media o superior

Alerta	Severidad	Dictamen	Fundamento
Path Traversal en /cuentas?documento	Alta (confianza baja)	Falso positivo	ZAP sustituyó el valor del parámetro por un nombre de ruta y la respuesta fue la misma página de resultados. Se reprodujo manualmente con siete valores contra la aplicación directa: ninguna respuesta contiene el contenido de /etc/passwd ni una traza de error; se obtiene la página normal o una respuesta 404 de 179 bytes
Content Security Policy no establecida	Media	No reproducida	Todas las respuestas de la aplicación, incluidos un error 404, una redirección y un envío sin token CSRF, incluyen la cabecera. Las respuestas que ZAP observó sin ella eran páginas de bloqueo del propio WAF
Proxy Disclosure	Media	Aceptada, informativa	Revela la existencia de un WAF; la aplicación responde 405 a los métodos TRACE y OPTIONS
HTTP Only Site	Media	Artefacto de la posición	Solo aparece porque se evalúa la aplicación directa, sin el cifrado TLS que aporta el WAF
Cabeceras X-Content-Type-Options, Permissions-Policy, Cross-Origin-Resource-Policy y Cross-Origin-Embedder-Policy ausentes	Baja	Las añade el WAF	A través del WAF, la misma ruta devuelve las cuatro cabeceras; el diseño reparte las cabeceras entre Django y BunkerWeb para no duplicarlas
Cookie Slack Detector	Baja	Informativa	Observación sobre atributos de cookie; las cookies de sesión llevan Secure, HttpOnly y SameSite=Lax

Cobertura de la superficie. ZAP alcanzó 20 de las 22 rutas de la aplicación (90,9 %) al combinar cinco roles. Las dos rutas restantes (reintento de emisión y segundo factor) no son alcanzables con una sesión inyectada, porque dependen de una solicitud en estado de error y de un desafío generado durante el inicio de sesión. La meta del plan era 95 %; no se alcanzó y se informa como tal. Esas rutas quedan cubiertas por la matriz de autorización de 440 celdas y por los escenarios de ingreso.

4. Inyección SQL con sqlmap

Tabla 4. Resultados de sqlmap

Corrida	Nivel	Objetivos	Parámetros inyectables
A través del WAF	3	4: búsqueda de cuentas, ficha de colaborador, detalle de solicitud y página de auditoría	0
Directa, sin WAF	5, incluida la cabecera Host	8, con prueba de segundo orden sobre el listado de solicitudes tras un envío	0

Durante la corrida directa, sqlmap emitió un aviso intermedio sobre las cabeceras User-Agent y Referer («boolean-based blind»), que la propia herramienta retiró en su veredicto final. Se trata de un falso positivo

producido por una página dinámica; el código de la aplicación no lee esas cabeceras. La cadena de auditoría permaneció íntegra tras la corrida.

La defensa de fondo es el uso exclusivo del ORM de Django y de consultas parametrizadas, verificado de forma estática con las reglas de seguridad de ruff y mediante el defecto sembrado de «consulta construida con una cadena formateada». El WAF constituye una segunda capa, no la única.

5. Superficie de red

Tabla 5. Puertos y exposición (nmap, todos los puertos TCP)

Servicio	Puertos abiertos	Alcance
bunkerweb	80 y 443 hacia el exterior; 8080, 8443 y 5000 internos	Único servicio publicado al público
web (aplicación)	8000	Red interna «app»
glpi	80	Red interna «app»
worker (integración)	Ninguno	No escucha conexiones
mariadb	3306	Red «db_net», aislada del exterior
postgres	5432	Red «pg_net», aislada del exterior
grafana y fluent-bit	3000 y 24224	Únicamente en 127.0.0.1 (excepción no documentada al principio de publicación única; hallazgo B-27)

Interfaz de administración de BunkerWeb (puerto 5000). El puerto responde por TCP desde la red «app», y no solo desde la red del planificador, como indicaba la documentación (hallazgo B-29). Se verificó de forma activa, con y sin token y sobre dos rutas: las seis combinaciones terminan con el cierre de la conexión; desde la red del planificador, el token correcto se procesa y el incorrecto o ausente no. La protegen el token de acceso y la lista blanca de direcciones.

6. Configuración de la capa TLS

La herramienta testssl.sh evaluó el dominio app.localhost. El borde ofrece únicamente TLS 1.2 y TLS 1.3, con suites de cifrado autenticado, secreto perfecto hacia adelante y HSTS con vigencia de un año. No se detectó vulnerabilidad en las pruebas de Heartbleed, ROBOT, POODLE, BEAST, SWEET32 ni RC4. El certificado es autofirmado (CN www.example.com), que es lo previsto por la arquitectura: el sistema no tiene exposición pública y no usa certificados emitidos por una autoridad pública. El navegador muestra una advertencia que se acepta una vez.

7. Vulnerabilidades en imágenes de contenedores

Las imágenes se reescanearon con Trivy el 25 de octubre de 2026, después de reconstruir la imagen propia con la dependencia certifi corregida. Se priorizó con el catálogo de vulnerabilidades explotadas activamente de CISA (KEV, versión 2026.10.23, con 1 756 entradas) y con la probabilidad de explotación EPSS.

Tabla 6. Vulnerabilidades por imagen

Imagen	Críticas	Altas	Con corrección disponible	EPSS >= 10 %
jml-app (aplicación)	0	44	0	0
BunkerWeb 1.6.15	1	24	25	2
BunkerWeb scheduler 1.6.15	2	7	9	1
GLPI 11.0.11	13	203	1	0
MariaDB 11.4	1	25	26	0

Las 139 CVE distintas detectadas no figuran en el catálogo KEV. La imagen propia pasó de una vulnerabilidad crítica (certifi) a ninguna; sus 44 vulnerabilidades altas corresponden al sistema operativo Debian 13.7, para las cuales no existe versión corregida (hallazgo B-18, aceptado y revisado en cada actualización). Las imágenes de terceros conservan vulnerabilidades críticas con exención escrita (hallazgo B-31); las que poseen corrección se resuelven actualizando el identificador de la imagen. Las imágenes están fijadas por su resumen criptográfico, lo que garantiza reproducibilidad pero impide recibir correcciones automáticas; la propuesta P-2 establece una revisión mensual.

8. Bases de datos

Tabla 7. Controles verificados en PostgreSQL 17

Control	Resultado esperado	Resultado obtenido
Propietario de las tablas (ADR-028)	El rol de migraciones, no el de la aplicación	Correcto en las 26 tablas
Permisos del rol de la aplicación sobre la auditoría	Solo inserción y lectura	Correcto; la actualización y la eliminación se deniegan
Inmutabilidad de una solicitud aprobada	Un disparador impide modificarla	Correcto
Transiciones de estado inválidas	Un disparador las impide	Correcto
Seguridad por filas (RLS)	Activa en todas las tablas del esquema de la aplicación	Correcto tras aplicar la migración 0006 (B-23)
Permisos otorgados a PUBLIC	Ninguno	0
Roles anon y authenticated	Sin inicio de sesión ni privilegios	Correcto

Además, el catálogo local se comparó con el de un proyecto de Supabase usado en una etapa anterior del desarrollo, en modo de solo lectura y con autorización escrita: son idénticos en columnas, restricciones, índices, disparadores, funciones, políticas, privilegios y versión. La comparación reveló que las nueve tablas del propio framework no tenían seguridad por filas activa (hallazgo B-23). La corrección es la migración 0006, que el 25 de octubre de 2026 se aplicó a la base local de la arquitectura vigente; la medición posterior confirmó la seguridad por filas en todas las tablas, ningún privilegio para anon y authenticated y ningún puerto publicado por el contenedor de la base de datos.

En MariaDB, la base de GLPI, el parámetro local_infile permanece activo y el tramo entre GLPI y la base no usa TLS (hallazgo B-30); el usuario de GLPI no posee el privilegio FILE y la red es interna.

9. Endurecimiento de contenedores (CIS Docker Benchmark)

Se ejecutó Docker Bench for Security sobre las secciones de imágenes y de contenedores en ejecución: 42 comprobaciones y 12 avisos, que corresponden a procesos que se ejecutan como administrador en MariaDB y PostgreSQL, ausencia de confianza de contenido, ausencia de comprobación de salud en algunas imágenes, perfil AppArmor, capacidades añadidas en GLPI, puertos privilegiados, ausencia de límites de CPU y de procesos, sistema de archivos con escritura y política de reinicio. Respecto de la evaluación anterior, ya no se presentan los avisos de SELinux, de límite de memoria ni de nuevos privilegios. Las secciones del anfitrión no se midieron. La corrección propuesta (hallazgo B-33) consiste en añadir read_only, un límite de procesos y un límite de CPU a los servicios que lo admiten.

10. Borde de protección (BunkerWeb)

El script de pruebas del WAF envía tráfico normal y siete ataques a los dominios de la aplicación y de GLPI: inyección SQL por GET y por POST, secuencias de comandos entre sitios, recorrido de rutas, inyección de comandos, Log4Shell por cabecera y un escáner identificado por su User-Agent. En todos los casos el tráfico normal recibió 200 o 302 y cada ataque recibió 403. Durante la auditoría no fue necesario crear ninguna exclusión del conjunto de reglas; la única vigente se describe al final de esta sección. Catorce variantes de cabeceras hostiles fueron bloqueadas o atendidas sin error de servidor, y la base de datos permaneció íntegra.

Se identificó una consecuencia indeseada del diseño del limitador: una persona que navega con rapidez puede recibir el código 429 y, si acumula varios, el bloqueo de su dirección durante una hora (hallazgo B-36, severidad media). Se corrigió con la decisión ADR-032: el límite de frecuencia sigue respondiendo 429, pero ese código ya no cuenta para el bloqueo por mal comportamiento. Una ráfaga de 26 respuestas 429 ya no bloquea, mientras que 25 respuestas 404 seguidas sí lo hacen, y el WAF siguió bloqueando los siete ataques en los dos dominios.

Al usar GLPI a través del WAF apareció además un falso positivo del conjunto de reglas: la regla 953100, que busca mensajes de error de PHP en las respuestas, cortaba el catálogo de traducciones de GLPI (/front/locale.php) y el navegador recibía el código 500 (hallazgo B-39). Se resolvió con una exclusión puntual de esa regla, limitada a esa ruta del dominio de GLPI, sin desactivar el resto del conjunto de reglas.

11. Hallazgos de esta área

Tabla 8. Hallazgos asociados a las pruebas de vulnerabilidades

Identificador	Severidad	Descripción	Estado
B-04	Media	Las pruebas activas no se habían medido con el WAF delante	Verificado
B-05	Baja	sqlmap en nivel 3 no prueba la cabecera Host	Verificado con el nivel 5
B-18	Baja	44 vulnerabilidades del sistema operativo sin corrección en la imagen propia	Aceptado
B-27	Baja	Grafana y fluent-bit publican en 127.0.0.1	Abierto, decisión del equipo
B-29	Informativa	La interfaz de administración del WAF responde en la red «app»	Abierto, corrección documental
B-30	Baja	local_infile activo y tramo GLPI–MariaDB sin TLS	Abierto
B-31	Media	Vulnerabilidades críticas en imágenes de terceros	Aceptado con exención
B-33	Baja	Doce avisos de endurecimiento de contenedores	Abierto
B-36	Media	El limitador del WAF puede bloquear a una persona legítima	Corregido (ADR-032)
B-38	Baja	En la arquitectura local, el volumen de los soportes de vinculación se montaba sin la opción noexec	Corregido y verificado
B-39	Baja	Una regla del CRS cortaba el catálogo de traducciones de GLPI	Corregido con una exclusión puntual

12. Limitaciones

1. Los tramos internos entre contenedores (aplicación–PostgreSQL, trabajador–GLPI y GLPI–MariaDB) no usan TLS; se apoyan en redes internas de Docker (hallazgos B-30 y B-32).
2. La cobertura de superficie de ZAP fue de 90,9 %, inferior a la meta de 95 %.
3. Un escáner solo evalúa las rutas que alcanza con una sesión; las rutas inaccesibles se cubrieron con otras pruebas, que no son equivalentes.
4. No se ejecutaron pruebas activas contra Supabase Auth ni contra ningún otro servicio de terceros.

13. Reproducibilidad

Cada medición conserva su comando exacto, su salida con los secretos enmascarados, la versión de la herramienta, el commit y la fecha. Los informes completos de ZAP, los registros de sqlmap y las salidas de nmap, testssl.sh y Trivy se encuentran en la carpeta de evidencias de la auditoría (docs/entregables/auditoria/evidencias/vulnerabilidades).